



Assignment 1: Evaluating and Implementing Secure Authentication Factors		Weighting: 15% of final grade
Individual or teamwork of 2 or 3		
Student identification		
Last Name	First Name	McGill ID
1- TARIQ	MUHAMMAD IBTISAM	261265753
2-		
3-		
Course Title and Number	Term	Section
CCCS 450 – Access Control and Defence Methods	Winter 2025	774
Course Lecturer	Course Assistant	Due Date
Dr. Esaie Kuitche Kamela		Jan. 23th

“Plagiarism, including the use of ChatGPT or any other automated writing assistance, is strictly prohibited for this assignment. All submissions will be checked for originality, and any plagiarism will be met with appropriate consequences. Your work must be entirely original and properly referenced.

However, you may use tools for experiments, demonstrations, and screenshots (e.g., setting up MFA, simulating attacks, testing authentication apps). Your explanations must be in your own words, clearly reflecting your understanding.”

Steps to complete the assignment

- Read the questions in this document.
- Upload your answers (Word/PDF document) to myCourses.

Evaluation Criteria

- Maximum point: **40**

Format Requirements

- Font size 11.
- Maximum of 20 pages (excluding this page).

Description

In this assignment, you will evaluate the security of authentication factors in real-world contexts.

Instead of only describing them, you will analyze, test, and demonstrate how they are used, including practical screenshots and tool outputs.

You will:

- Compare the three authentication factors.
- Select the most secure for your chosen scenario.
- Identify vulnerabilities and propose mitigations.
- Provide a proof-of-concept demonstration.
- Analyze a real-world case (mother's maiden name as authentication).

Learning Outcomes

By completing this assignment, students will be able to:

- Explain authentication factors not only conceptually, but operationally, including how they are implemented, attacked, and defended in real systems.
- Evaluate authentication mechanisms within a specific context, recognizing that security effectiveness depends on threat models, users, and operational constraints.
- Analyze real-world authentication weaknesses, including legacy practices still used in industry.
- Design and justify secure authentication choices, balancing security, usability, cost, and deployability.
- Translate theoretical authentication concepts into concrete technical configurations, tools, and workflows used in practice.

Important note on academic integrity

You may use tools for **experimentation, configuration, testing, and screenshots** (e.g., MFA setup, password testing tools, biometric configuration).

Your explanations, analysis, and justification must be written entirely in your own words.

Steps to Complete the Assignment

I. Part A – Authentication Factors in Practice (30 points)

A.1 Scenario Definition and Threat Context (3 points)

Task: Select a realistic scenario where authentication is critical (e.g., hospital EHR system, corporate VPN, online banking, cloud admin console).

You must:

- Clearly describe the system being protected
- Identify **who the users are**
- Identify **what an attacker would want**
- State at least **two realistic threats**

Grading expectations

- 1 pt: Clear scenario description
- 1 pt: Correct identification of users and assets
- 1 pt: Realistic threat identification

Scenario description

The scenario selected is a hospital electronic health record (EHR) system used by clinical staff to access patient information. This system stores highly sensitive medical data and is accessed daily to support diagnosis, treatment, and care coordination.

Users and assets

The primary users are doctors, nurses, and administrative staff. The key assets being protected are patient medical records, including personal identifiers, diagnoses, medications, and treatment history.

Attacker motivation

An attacker would want to gain unauthorized access to patient records to steal sensitive information, commit identity fraud, or sell health data.

Realistic threats

- Stolen or guessed credentials allowing an attacker to log in as a legitimate user
- Abuse of excessive privileges by an internal user accessing records beyond their role

A.2 Comparative Analysis of Authentication Factors (10 points)

Analyze **all three authentication factors** in *your chosen scenario*:

- Something you know
- Something you have

- Something you are

For **each factor**, you must include:

1. **How it is typically implemented in real systems**
2. **Its main strengths**
3. **Its main weaknesses**
4. **One hands-on demonstration (screenshot required)**

Hands-on requirements

- Knowledge: password strength testing, cracking demo, or policy enforcement
- Possession: MFA app, hardware token, or OTP system
- Inherence: biometric login (phone, OS, or system)

Grading expectations

- 6 pts: Quality and accuracy of analysis (2 pts per factor)
- 3 pts: Relevance and correctness of demonstrations
- 1 pt: Integration of human factors (usability, social engineering, errors)

Implementation in real systems

This factor is typically implemented using passwords or PINs. Hospital staff log in with a username and password issued by the organization.

Strengths

- Simple and inexpensive to deploy
- Familiar to all users

Weaknesses

- Passwords can be forgotten or reused across systems
- Vulnerable to phishing, brute-force, and credential leaks

Human factors

Users often choose weak passwords or reuse the same password due to workload and time pressure, which increases risk.

Take the Password Test

Tip: It's often better to have longer passwords than shorter, more complex ones

Show password: ☐

••••••••••

Very Weak

12 characters containing: Lower case Upper case Numbers Symbols

Time to crack your password:
0.02 seconds

Take the Password Test

Tip: It's often better to have longer passwords than shorter, more complex ones

Show password: ☐

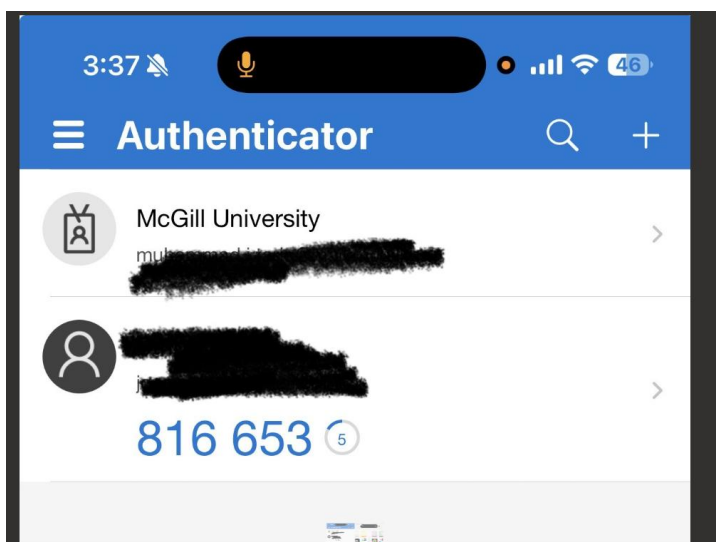
••••••••••••••

Very Strong

17 characters containing: Lower case Upper case Numbers Symbols

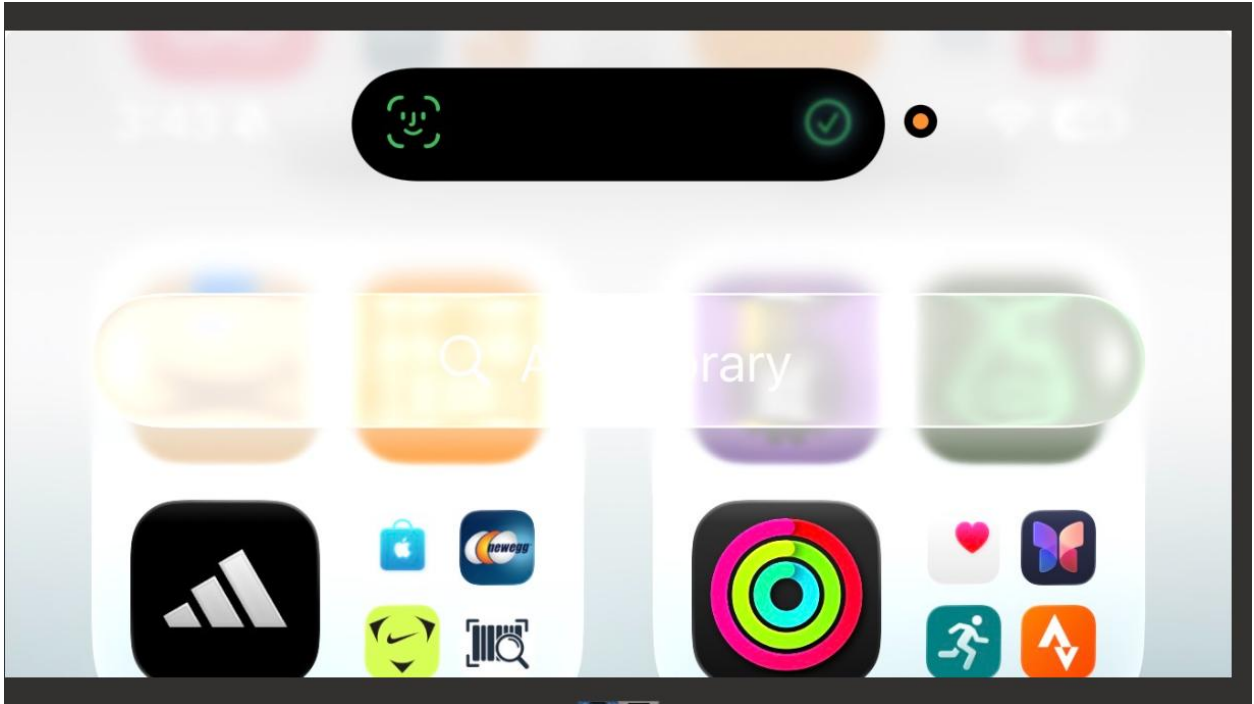
Time to crack your password:
4 years

- This shows that short/common passwords are rated weak and easier to guess. Stronger passwords with length and variety score higher.



his screenshot demonstrates the use of Google Authenticator as a possession-based authentication factor for my Stripe account. The app generates a temporary verification code that

is required in addition to a password during login. Because the code is tied to a physical device and refreshes frequently, it adds an extra layer of protection against unauthorized access caused by stolen credentials.



This screenshot shows Face ID being used as a biometric authentication factor. Unlike passwords or authentication apps, Face ID verifies identity based on a physical characteristic of the user.

A.3 Chosen Factor: Vulnerability & Mitigation Analysis **(7 points)**

Select **one authentication factor** you would *recommend* for your scenario.

Tasks

1. Identify **one concrete vulnerability**
2. Explain **how an attacker could exploit it**
3. Propose:
 - one **short-term mitigation**
 - one **long-term mitigation**

4. Include **at least one applied example or configuration screenshot**

Grading expectations

- 3 pts: Accurate attack explanation
- 2 pts: Quality of mitigation strategies
- 2 pts: Realistic and relevant applied example

For the hospital EHR system, I recommend using multi-factor authentication (MFA) that combines a password with a one-time password generated by an authenticator app.

Identified Vulnerability

A key vulnerability of password-based authentication is **phishing**, where attackers trick users into revealing their login credentials.

How an Attacker Could Exploit This Vulnerability

An attacker could send a realistic email pretending to be hospital IT support or the EHR login system. The email may include a link to a fake login page that looks identical to the real one. If a user enters their username and password, the attacker can capture those credentials and attempt to log in as the user.

Mitigation Strategies

- **Short-term mitigation:** Enforce multi-factor authentication so that a stolen password alone is not enough to gain access to the system.
- **Long-term mitigation:** In the long term, the goal should be to move away from heavy reliance on passwords by strengthening authentication rules and regularly reminding users about the risks of credential theft, while making broader use of multi-factor authentication throughout the organization.





McGill

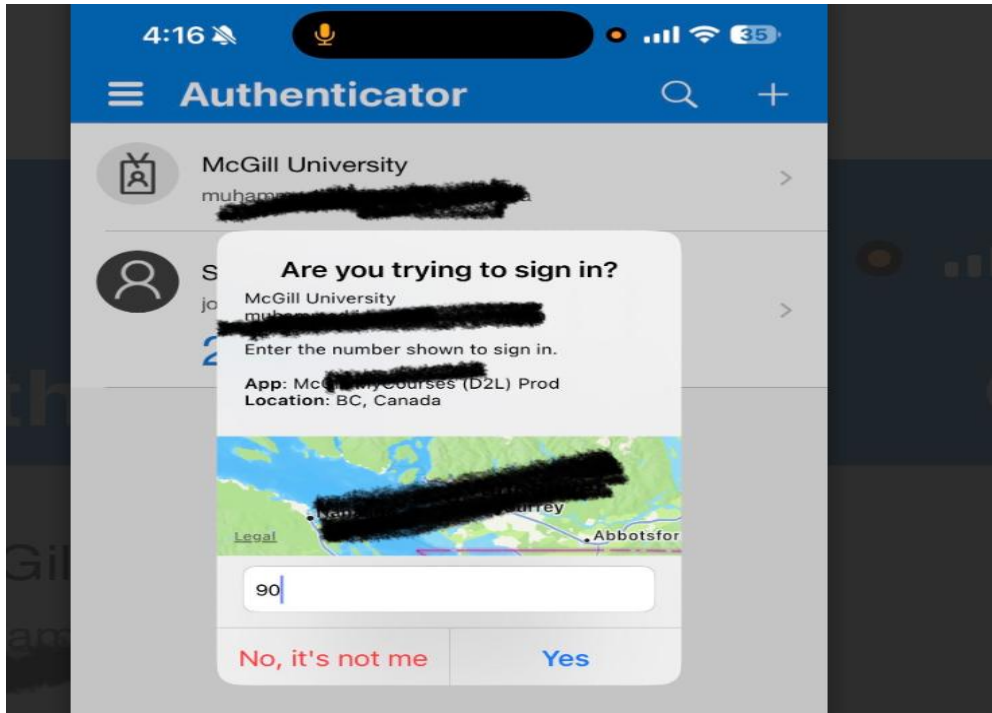
School of Continuing Studies École
d'éducation permanente

Approve sign in request



Open your Authenticator app and approve the request. Enter the number if prompted.

90



The screenshot shows multi-factor authentication enabled using an authenticator app. This demonstrates how requiring a second factor prevents attackers from accessing the system even if a password is compromised.

A.4 – Real-World Deployment & Operational Constraints **(10 points)**

Assume you are hired to **deploy authentication** for your scenario in a real organization.

You must address:

1. **Target environment**
 - Operating systems
 - On-prem vs cloud
2. **Chosen technologies**
 - Authentication protocols
 - Tools or platforms (generic names acceptable)
3. **Operational considerations**
 - User onboarding
 - Recovery if authentication fails
 - Maintenance and updates
4. **Trade-offs**
 - Security vs usability
 - Cost vs protection
 - Scalability

You may include:

- Diagrams
- Architecture sketches
- Configuration screenshots

Grading expectations

- 4 pts: Technical realism and coherence
- 3 pts: Consideration of operational constraints
- 3 pts: Quality of trade-off analysis

Target Environment

The authentication system would be deployed in a hospital environment where staff access an electronic health record (EHR) system from hospital workstations and approved personal devices. The system must support frequent access while protecting highly sensitive patient data.

Operating Systems and Infrastructure

The environment includes a mix of operating systems, such as Windows-based workstations at nursing stations and mobile devices used by clinicians. The EHR system is assumed to be hosted in a centralized environment, with authentication services supporting both onsite and remote access.

Authentication Technologies Used

Authentication is implemented using a combination of passwords and a one-time password generated by an authenticator app.

You can use authenticator app for this from the app store.

Operational Considerations

User onboarding

New users need to be set up quickly and clearly, including guidance on creating passwords and registering an authenticator app. This is especially important in healthcare environments where staff frequently rotate between shifts and new employees are onboarded regularly.

Recovery and access issues

There should be clear procedures for situations where a user loses access to their authentication device or is unable to log in. In these cases, support staff should verify the user's identity before restoring access to avoid insecure workarounds, such as sharing accounts or bypassing authentication controls.

Maintenance and monitoring

Authentication systems require ongoing maintenance and monitoring. Login attempts and authentication events should be logged so that access can be reviewed, suspicious activity can be identified, and accountability is maintained.

Trade-Off Analysis

Security vs usability

multi-factor authentication improves security but introduces an extra step during login. In a healthcare setting, this balance must be carefully managed so that security controls do not interfere with timely access to patient information, particularly in urgent situations.

Cost vs protection

Although implementing MFA involves additional setup and support costs, it greatly reduces the risk of breaches caused by stolen credentials. Given the sensitivity of healthcare data, this trade-off is generally reasonable and justified.

Scalability

The authentication approach should be able to support many users without becoming difficult to manage. As the organization grows, the system must remain consistent and effective while still being easy for users and administrators to work with.

II. Part B – Case Study: Mother’s Maiden Name Authentication (10 points)

Some Canadian telecommunications companies and government agencies still ask for a user’s mother’s maiden name when creating an account. This information is later used to authenticate the customer during phone calls.

Example:

- Question: “What is your mother’s maiden name?”

B.1 Authentication Factor Classification (2 points)

Identify the authentication factor and explain **why it belongs to that category**.

B.2 Security Limitations (4 points)

List **five distinct security weaknesses**, clearly explained and non-overlapping.

Examples of dimensions:

- Predictability
- OSINT exposure
- Reusability
- Revocation difficulty
- Social engineering

B.3 Modern Replacement Design (4 points)

Assume you are consulting for **Tell Telecommunication**.

Propose a modern alternative that:

- Improves security
- Preserves usability
- Is deployable at scale

You must include:

- How it works
- Technologies involved
- At least one visual element (diagram, screenshot, or flow)

Student-Facing Checklist

Assignment 1 – Submission Checklist

Before submitting, verify that your assignment includes:

General

- ☐ Scenario is clearly defined and realistic
 - ☐ Explanations are written in **your own words**
 - ☐ Screenshots are labeled and explained
 - ☐ Claims are justified, not just stated
-

Part A

- ☐ All **three authentication factors** analyzed
 - ☐ At least **one hands-on demo per factor**
 - ☐ Human factors discussed (usability, errors, social engineering)
 - ☐ One concrete vulnerability clearly explained
 - ☐ Short-term **and** long-term mitigations proposed
 - ☐ Real-world deployment explained (OS, tools, users, recovery)
 - ☐ Trade-offs explicitly discussed
-

Part B

- ☐ Mother's maiden name correctly classified as an auth factor
 - ☐ Five **distinct** security weaknesses explained
 - ☐ Clear explanation of why it no longer works today
 - ☐ A modern alternative is proposed and justified
 - ☐ At least one diagram, screenshot, or flow included
-

What Strong Submissions Do

- Focus on **context**, not definitions
- Explain **why** a choice is secure, not just **what** it is
- Show awareness of **real operational constraints**
- Make trade-offs explicit